TITAN
COMPANY

IT Supplier Third-Party Risk Management (TPRM) Policy

Version 1.0

December-2024

[TITAN COMPANY LIMITED]

TCL-IS-031

TITAN – "INTERNAL"

Sensitivity: Internal

Document Information

Document Owner

Document Owner(s)	Organization Role
Col Rajmohan R (Retd)	Head IT Infrastructure & Information Security

Version control

Version	Status	Date	Author	Change description
1.0	Released	20th December, 2024	Akhtar Rizvi	New document

Document location

https://infosec.titan.co.in/policies/policies.php

Scheduled date of next review

January -2025

Implementation Criteria

This Policy is mandatory and must be complied

Document Sign-off

Sensitivity: Internal

	Name	Organization Role	Version Approved	Reviewal/ Approval Date
Reviewed By	Nishith Kumar Datta	Chief Information Security Officer	1.0	
Approved by	Col Rajmohan R	Head IT Infrastructure & Information Security	1.0	
Approved by	Krishnan Venkateswaran	Chief Digital & Information Officer	1.0	

Sensitivity: Internal

Table of Contents

1. **Policy Statement** 4
2. **Objectives** 4
3. **Scope** 4
4. **Review and implementation** 4
5. **Policy review** 4
6. **Communication** 4
7. **Responsibility** 4
8. **Terms Used** 5
9. **Pre-Engagement Steps** 6
10. **Engaging the TPRM Team** 6
11. **Applicability of TPRM** 6
12. **Vendor Onboarding and Categorization** 7
13. **Information security in supplier relationships** 8
14. **Assessment Evaluation and Treatment** 8
15. **Risk Exception Process** 9
16. **Addressing information security within supplier agreements** 9
17. **Managing information security in the ICT supply chain** 10
18. **Monitoring and re-assessment of IT Suppliers** 10
19. **Vendor offboarding** 10
20. **Reporting** 10
21. **Management Commitment** 11
22. **Enforcement** 11
23. **Related Standards, Policies and Processes** 11

Sensitivity: Internal

1. Policy Statement

The **Titan Company Limited (TCL)** is committed to managing risks associated with third-party IT suppliers to ensure the confidentiality, integrity, availability, and reliability of its systems and data. This policy establishes the framework for assessing, monitoring, and mitigating risks posed by third-party IT suppliers throughout their lifecycle, from onboarding to termination of the relationship.

All Technology Vendors or suppliers providing goods or services to the organization must undergo a thorough risk assessment prior to engagement and at regular intervals during the contract term. This includes evaluating their security posture, regulatory compliance, operational resilience, and potential impacts on the organisation's objectives.

2. Objectives

The primary objective of this **Third-Party Risk Management (TPRM) Policy** for IT Supplier Assessment is to establish a structured approach for identifying, assessing, mitigating, and monitoring risks associated with third-party IT suppliers. This ensures that the organization's systems, data, and operations remain secure, compliant, and resilient throughout the supplier lifecycle. This policy underscores the organization's commitment to proactive third-party risk management to protect its assets, stakeholders, and reputation.

3. Scope

This policy applies to all employees, departments, and subsidiaries of Titan Group involved in the management of IT suppliers providing staff augmentation and digital service.

4. Review and implementation

Titan will strive to ensure that every individual impacted by the requirements of the policy, knows about the policy and about the arrangements and controls that operate in the areas of responsibility with which they are concerned.

5. Policy review

"Head IS or CISO" will review this policy on an annual basis, or following a significant incident or organisational / technical change

6. Communication

A current version of the policy will be made available to all concerned staff via E-mail or web portal or a hard copy as appropriate to a stakeholder.

7. Responsibility

Sensitivity: Internal

"Head IS" shall be responsible for enforcing this policy and developing a mechanism to continuously monitoring complaints

8. Terms Used

8.1 The terms "Company", "Organization" "TCL" and "Titan" as used in this document refer to "TITAN COMPANY LIMITED INCLUDING SUBSIDIARIES COMPANIES".

8.2 The term "IT Department" as used in this document implies the Company's Systems function.

8.3 The term "Head IT" refers to Head of system function of TITAN COMPANY LIMITED.

8.4 The term "Head IS" refers to Head of Information Security of TITAN COMPANY LIMITED.

8.5 The term "ISMS" refers to "Information Security Management systems" of TITAN COMPANY LIMITED.

8.6 The term "ISP" refers to "Information Security Policy" of TITAN COMPANY LIMITED.

8.7 The term "CDIO" refers to Chief Digital & Information Officer of Titan Company Limited.

8.8 The term "ISAC" refers to "Information Security Apex Committee" of TITAN COMPANY LIMITED.

8.9 The term "Titan SPOC" : The Titan SPOC manages communications and coordination for TPRM activities, acting as the primary liaison between the organization and vendors. They ensure smooth assessments, issue resolution, and alignment of responses with the engagement.

8.10 The term "Vendor/Supplier" refers to an organization or individual that provides goods or services to another organization. Vendor/Suppliers may be subject to risk assessments to ensure they meet the necessary compliance and security standards.

8.11 The term "TPRM Team" refers to a team, within the Information Security vertical, identifies, assesses, and mitigates risks related to third-party vendors. They evaluate vendor relationships from a cybersecurity perspective, ensure regulatory compliance, and maintain customer and stakeholder trust.

8.12 The term "Tool" refers to a software solution used to automate vendor risk assessments, risk identification, and ensure compliance with security standards and regulatory requirements. The organization currently utilizes the One Trust tool for these purposes

Sensitivity: Internal

9. Pre-Engagement Steps

9.1 TPRM Certificate Repository: The TPRM Team is responsible for maintaining the repository of TPRM Assessment Certificates, which is accessible at [repository location].

9.2 Certificate Availability Check: For all the engagement other than software licenses or hardware procurement; Before engaging with the TPRM Team, the requester must check the availability of the vendor's TPRM Assessment Certificate in the repository.

9.3 Attachment to MPR Requests: If a valid TPRM Assessment Certificate is available, the requester must attach the certificate to the purchase or MPR (Material Procurement Request) documentation.

9.4 Certificate Validation: The Digital Procurement Team is responsible for validating the vendor's TPRM Assessment Certificate for coverage and validity.

- **Valid Certificate:** If the certificate is valid and aligns with the engagement's scope, the engagement proceeds without further TPRM Team involvement.
- **Invalid or Missing Certificate:** If the certificate is unavailable or invalid, the Digital Procurement Team will instruct the requester to engage with the TPRM Team.

10. Engaging the TPRM Team

Engagement with the TPRM Team must be initiated through one of the following pathways:

10.1 Direct Engagement: The requester contacts the TPRM Team directly to initiate the TPRM assessment process.

10.2 Referral via Digital Procurement Team: The Digital Procurement Team redirects the requester to the TPRM Team when the TPRM Assessment Certificate is unavailable or invalid.

10.3 Referral via Corporate Legal Team: The Corporate Legal Team redirects the requester to the TPRM Team for incorporating IT-specific contractual clauses. Note that IT clauses will only be provided upon completion of the TPRM assessment.

11. Applicability of TPRM

Upon receipt of a vendor engagement request, the designated Titan SPOC shall coordinate a meeting involving the vendor, the InfoSec team, the Business Team, and other relevant stakeholders. This meeting shall focus on understanding and reviewing key aspects of the engagement, including but not limited to:

- Scope of Services
- Technological Integrations and Workflow design documents.
- Data Access and Collection
- Other Documentation relevant to engagement.

Sensitivity: Internal

Following the engagement review, the TPRM Team shall evaluate whether the vendor engagement falls within the In-Scope or Out-of-Scope categories.

a) **Out-of-Scope Engagements:** hardware procurement, standalone software licenses, and one-time short engagements that do not require legal agreement and backend integration with Titan's environment.
b) **In-Scope Engagements:** Every engagement other than out of scope Engagements should be evaluated for TPRM Applicability. (Eg. IT services sourcing, cloud computing, API integrations, data handling, SaaS/PaaS services, digital marketing, and other engagements involving data access or technological integration.)

12.Vendor Onboarding and Categorization

12.1 Vendor Onboarding Information Collection: Upon determination of the necessity for a TPRM assessment, the Titan SPOC shall provide the following details, along with the agreement, to the TPRM team for onboarding process through the tool:

a) Name of the Vendor Company
b) Name and email address of the Vendor SPOC
c) Name and email address of the Titan SPOC
d) Vertical (Internal)
e) Contact details, if applicable
f) Brief Scope of Services

The onboarding process will be automated through the OneTrust tool to streamline the evaluation process.

12.2 Internal Vendor Criticality Assessment: Only upon receiving the above information, the assessment begins with triggering the TPRM Questionnaire, consisting of multiple-choice questions, to the internal Titan SPOC via the OneTrust tool. The Titan SPOC is required to complete the questionnaire, providing accurate responses based on the engagement's applicability and risk level. Based on responses from Titan SPOC the vendor will be categorised into Low Risk, Medium Risk, or High Risk.

12.3 TPRM Assessment

The Vendor Risk Assessment is automatically initiated via the OneTrust tool for the Vendor after the completion of internal vendor criticality Assessment. Assessment type depends on the engagement's scope as defined in applicability section:

a) **Augmented Staff Vendor Assessment Questionnaire**: For vendors providing human resources related support staff.
b) **Vendor Risk Assessment (SIG Lite Assessment):** For vendors providing services other than staff augmentation

Vendors are required to respond to the assessment questions with "Yes," "No," or "Not Applicable," and provide justifications and supporting documentation where applicable, Supported by the related documentations

13. Information security in supplier relationships

13.1 Information security requirements for mitigating the risks associated with supplier access to the organization assets should be agreed with supplier and documented.

13.2 Identify and document the type of suppliers

13.3 Define the type of access that will be allowed to different type of supplier

13.4 Define minimum information security requirement for each type of information and type of access to serve individual supplier agreement based on organization business need and requirements.

13.5 Process and procedure to monitor the adherence to establish information security requirements for each supplier and type of access.

13.6 Type of obligation applicable to supplier to protect the organization's information.

13.7 Handling incidents associated with supplier access.

13.8 Contingency arrangement of the supplier.

13.9 Awareness training for the organizational personal involved in acquisition.

13.10 Managing the necessary transitions of information, information processing facilities and anything else that needs to be moved, ensuring information security is maintained throughout the transition period.

14. Assessment Evaluation and Treatment

The Evaluation and Treatment stage is integral to the Third-Party Risk Management (TPRM) process, ensuring that all identified risks associated with vendor engagements are systematically assessed and mitigated. This stage is conducted through the tool.

14.1 Review of Questionnaire Responses: The TPRM Team performs a comprehensive review of vendor responses to the assessment questionnaire using the designated assessment tool. The review process incorporates Various controls and applicable Compliance requirements to ensure a thorough evaluation of risks and compliance with security standards.

14.2 Addressing Flagged Risks:

a) **Document Analysis:** Supporting documentation provided by vendors is reviewed to validate the responses in the assessment.

b) **Gap Identification and Follow-Up:** Discrepancies or gaps between assessment **responses** and supporting **documentation** are identified. Follow-up questions are sent to the vendor, and discussions are conducted with the vendor and the Titan SPOC to clarify identified risks.

c) **Mitigation Strategies:** Mitigation measures are implemented to address identified risks, which may include:

- Drafting additional Information Security (InfoSec) clauses.

- Requesting alternative documentation or further justifications from the vendor.
- Request the vendor to work on the Gaps

d) **Drafting Information Security Clauses:** Tailored InfoSec clauses are drafted to address specific risks identified during the assessment process. These clauses ensure alignment with security standards and compliance with applicable legal and regulatory requirements.

15. Risk Exception Process

The Risk Exception Process is a critical component of the Third-Party Risk Management (TPRM) policy, providing a structured approach to managing inherent risks flagged during the evaluation of vendor engagements.

When the TPRM tool identifies an inherent risk, the TPRM team proactively works to mitigate it and reduce the residual risk to an acceptable level through the following steps:

15.1 Vendor Communication:

a) Engage with the vendor to understand the root cause of the flagged risk.

b) Collaborate on identifying and implementing feasible mitigation strategies.

15.2 Alternative Solutions:

a) Propose alternative measures, tools, or processes to address the risk while ensuring operational efficiency is maintained.

15.3 Risk-Specific Clauses:

a) Draft and incorporate tailored contractual clauses to mitigate identified risks.

b) These clauses are designed to ensure compliance, enforce vendor accountability, and safeguard Titan's interests.

15.4 Risk Acceptance:

a) If the inherent risk cannot be mitigated through the above measures The non mitigated risks will be presented to business to facilitate the informed decision. If required Titan SPOC will initiate the risk acceptance process via iMitra

16. Addressing information security within supplier agreements

All relevant information security requirements should be established and agreed with each supplier that may access, process, store, communicate or provide IT infrastructure components for the organization information's.

16.1 Description of information to be provided or accessed and method of providing the access.

16.2 Classification of information as per the organization classification scheme.

16.3 Legal and regulatory requirement including data protection, intellectual property rights and copyright.

16.4 Obligation of each contractual parties to implement an agreed set of controls including access controls, performance review, monitoring, reporting and auditing.

16.5 Rule of acceptable use of information.

16.6 Information security policies relevant to a specific contract.

16.7 Incident management requirement and procedure.

16.8 Training and awareness requirements.

16.9 Relevant agreement partner, including a contact person for information security issues.

16.10 Relevant regulation from sub-contracting, including the controls that needs to be implemented.

16.11 Screening requirement.

16.12 Right to Audit for supplier's security controls.

16.13 Supplier obligation to periodically deliver an independent report on the effectiveness of controls.

16.14 Supplier's obligation to comply with the Titan's security requirements.

17. Managing information security in the ICT supply chain

17.1 Agreement with supplier should include requirements to address the information security risks associated with information and communication technology services.

17.2 Supplier is required to propagate the organization's security requirements and appropriate security practice throughout the supply chain even if supplier subcontract for parts.

17.3 Implementing a monitoring process and acceptable method of validating that delivered information and communication technology products and services are adhering to stated security requirements.

18. Monitoring and re-assessment of IT Suppliers

18.1 Vendors are subject to regular re-assessments based on their assigned risk category, ensuring that Titan can promptly identify and address any evolving risks.

- **High-Risk** Vendors: Re-assessed every **365 days** (1 year).
- **Medium-Risk Vendors:** Re-assessed every **545 days** (approximately 1.5 years).
- **Low-Risk Vendors:** Re-assessed every **730 days** (2 years).

19. Vendor offboarding

19.1 Upon receipt of a vendor off-boarding request, the TPRM team initiates the off-boarding process by triggering the Off-boarding Assessment through the designated tool. Titan SPOC is responsible for ensuring all necessary actions are taken to mitigate risks, fulfill contractual obligations, and ensure compliance

20. Reporting

20.1 Effective quarterly reporting to management includes a breakdown of the number of vendors, those that have completed the TPRM process, and action item on Titan or Vendor

SPOC for any pending assessments. It provides an overview of the current status of vendor risk management.

21. Management Commitment

21.1 Titan is dedicated to proactively managing third-party risks associated with IT suppliers by conducting comprehensive risk assessments.

21.2 To support this commitment, Titan has established a robust framework that integrates and promotes the adoption of information security and compliance principles across the organisation.

21.3 Governance and oversight of information security and Third-Party Risk Management (TPRM) for IT suppliers are provided by the Information Security Apex Committee.

22. Enforcement

22.1 Non-compliance with this policy may result in disciplinary actions, including but not limited to, termination of employment or contract, as per the organization's disciplinary procedures.

23. Related Standards, Policies and Processes

- TCL-IS-000 Information Security Policy

**********End**********